Honeypot Report

What the internet throws at an exposed server

Findings from an internet-facing multi-honeypot sensor in Australia: who connected, what they targeted, what they did once inside and what organisations should do about it.



AUTHOR Zachary Lehmann

PUBLISHED November 2026
VERSION 1.0 · Public release

REPORT

Contents

1. Executive summary . . . 3

2. How the data was collected . . . 4

3. Sources: everywhere and nowhere . . . 5

4. Services attackers look for . . . 6

5. RDP and SSH: the password grind . . . 7

6. What attackers do once they are 'in' . . . 8

7. Exploits, phone fraud, databases and industrial systems . . . 9

8. Everything the sensor recorded . . . 10

9. Lessons for anyone running something online . . . 11

Appendix: Indicators of compromise . . . 12

About this report

TITLE	Honeypot Report: What the internet throws at an exposed server
AUTHOR	Zachary Lehmann
PUBLISHED	November 2026
VERSION	1.0
CLASSIFICATION	TLP:CLEAR. May be shared freely.
DATA SOURCE	One multi-honeypot sensor on an Australian internet connection
SCOPE	359,560 events from 1,168 public IP addresses; the operator's own traffic removed

Attacker IP addresses and malware hashes are published as indicators of compromise for defenders. Nothing in this report identifies the sensor, its location beyond country level or its owner's network.

SECTION 01 · SUMMARY

Executive summary

359,560
events recorded from outside sources

1,168
unique source IP addresses

68
countries (by IP geolocation)

266
different networks (ASNs)

4,211
SSH / Telnet password guesses

64%
of source IPs already on public reputation blocklists

Key findings

A server on the open internet is found quickly and probed constantly by thousands of machines. Most of it is automated, cheap and noisy. A small part is targeted, scripted intrusion that ends with malware being dropped.

- **Remote Desktop (RDP) is the single most hammered service.** RDP drew 37,467 honeypot interactions. **98.6% of them came from one host**, a rented cloud server that made more than 18,000 separate RDP connection attempts.
- **Weak passwords are still the whole game for SSH and Telnet.** 4,211 login attempts came from 46 addresses. The top passwords were `123456`, `123` and `1234`. The username `root` was tried 1,515 times.
- **Once 'in', attackers moved fast.** They fingerprinted the system, searched for writable folders, uploaded a 3.4 MB Linux binary, made it executable and tried to escalate with `sudo`. The same payload was uploaded 5 times from 5 different addresses.
- **98.5% of SSH clients identified as** `SSH-2.0-Go`, the signature of automated Go-based brute-force tooling, not people.
- **Recent, critical web flaws are being sprayed blindly.** Detections included React Server Components / Next.js remote code execution (CVE-2025-55182, CVSS 10.0), Cisco IOS XE (CVE-2023-20198), Hikvision cameras and FreePBX phone systems.
- **Phone systems and industrial controls are on the menu too.** 1,413 SIP `INVITE` requests tried to place calls through a 'PBX' (toll fraud). Separately, 17 addresses probed an industrial-control decoy, mostly over IEC 60870-5-104, a power-grid control protocol.
- **Blocking by country does not work.** The busiest source geolocated to Australia. Most traffic came from commercial cloud and hosting networks, not from any one country.
- **AI tooling is a new target.** Attackers tried the username `claude` and probed `/mcp` and `/api/mcp`, the web endpoints used by AI-agent (Model Context Protocol) servers.
- **Reputation lists help a lot.** 751 of the 1,168 source addresses (64%) were already flagged by public reputation feeds.

SECTION 02 · METHOD

How the data was collected

What a honeypot is

A honeypot is a decoy. It looks like a real, vulnerable server, but it has no real data and is isolated from everything else, so anything that connects to it is, by definition, unsolicited. That makes it a clean way to see what attackers actually do on today's internet, without the noise of legitimate users.

The sensor is a **multi-honeypot platform** built from open-source components. It bundles around twenty decoy services with network-level monitoring:

COMPONENT	WHAT IT PRETENDS TO BE / DOES
Cowrie	SSH and Telnet server with a fake Linux shell that records logins, commands and uploaded files
RDP honeypot	Windows Remote Desktop login screen
Dionaea	SMB, MySQL, MSSQL, MongoDB, FTP, MQTT, PPTP VPN and other common services
SentryPeer	SIP / VoIP phone system
ConPot	Industrial control system (IEC 60870-5-104, SNMP and others)
Tanner, H0neytr4p	Web applications and known-vulnerable web endpoints
Cisco ASA, Redis, Heralding, Mailoney, others	VPN gateway, database, VNC, mail and more
Suricata, P0f, Fatt	Network intrusion detection, passive OS and client fingerprinting (they observe, they do not emulate)

Isolation. The sensor sat on its own network segment with no route to any real system and tightly restricted outbound access, so anything that 'compromised' it could not go further. Its management interface was never exposed to the internet.

Cleaning. All traffic from the operator's own administration and testing, from the sensor itself and from private address ranges was removed before analysis (roughly 144,000 records). What remains is 359,560 events from 1,168 public IP addresses.

Two kinds of number. *Events* include everything the network sensors logged (Suricata alerts, fingerprints and flows), so one connection can produce several events. *Honeypot interactions* (63,212) are only the records from the decoy services themselves. Where 'how many attackers' matters more than 'how loud', this report counts *unique source IP addresses*.

Limits worth knowing

IP geolocation shows where a server is, not where the person behind it is. Most attackers rent cloud servers or use compromised machines and proxies. Some sources are legitimate internet-scanning and research companies. Counts reflect a single sensor in a single location over one observation window, so treat them as a snapshot rather than a national statistic.

SECTION 03 · WHO CONNECTS

Sources: everywhere and nowhere

1,168 distinct public IP addresses touched the sensor, spread across 68 countries and 266 networks (autonomous systems). Counted by addresses, the United States and China lead, mostly because that is where the big cloud providers are.

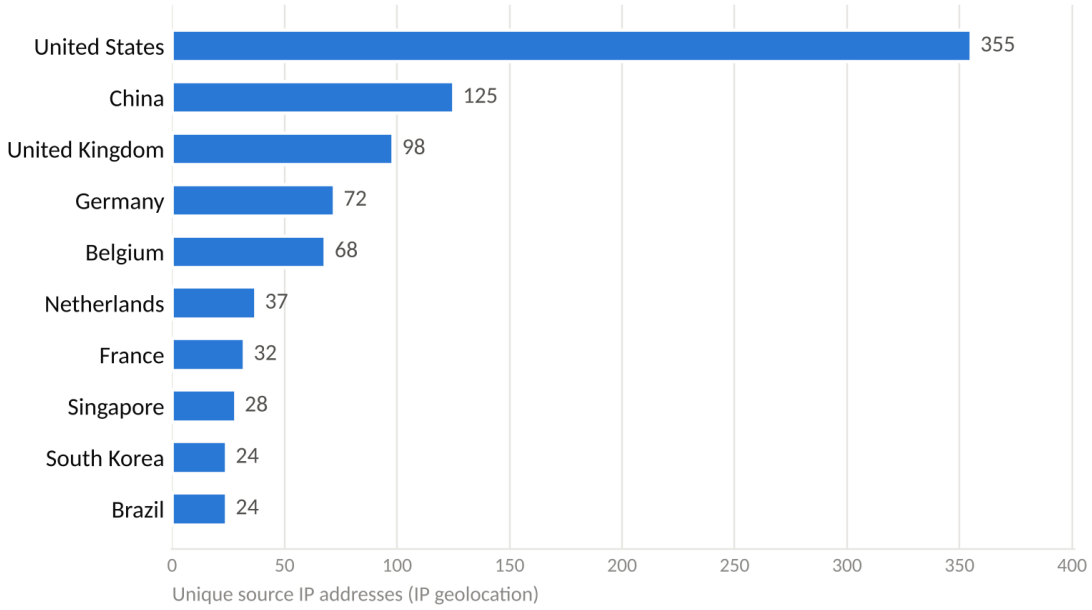


Figure 1. Countries ranked by unique source IP addresses.

Counted by volume instead, Australia comes first, with 261,487 events. That is almost entirely one machine: a rented server on Contabo's Asia hosting network, geolocated to Australia, that hammered RDP. One noisy host can rewrite a country chart, which is exactly why country blocking is a poor defence.

Networks with the most distinct sources

NETWORK (ASN)	UNIQUE IPS	WHAT IT IS
AS25369 Hydra Communications	82	Hosting network
AS211298 Driftnet	75	Internet-wide scanning company
AS15169 + AS396982 Google	120	Google Cloud
AS8075 Microsoft	54	Azure cloud
AS6939 Hurricane Electric	47	Transit and hosting
AS4837 China Unicom / AS4134 Chinanet	55	Chinese national carriers
AS213412 ONYPHE / AS209334 Modat	53	Attack-surface scanning companies
AS63949 Akamai (Linode) / AS14061 DigitalOcean	49	Cloud hosting

Cloud and hosting providers dominate. Their servers are cheap, disposable and come with clean-looking IP space, which is why they are the attacker's default launch pad.

SECTION 04 · WHAT THEY TARGET

Services attackers look for

Web ports, Telnet and SSH attract the widest range of sources. Most of those are scanners cataloguing what is online. The next tier is more telling: Remote Desktop, VoIP and databases that should never face the internet at all.

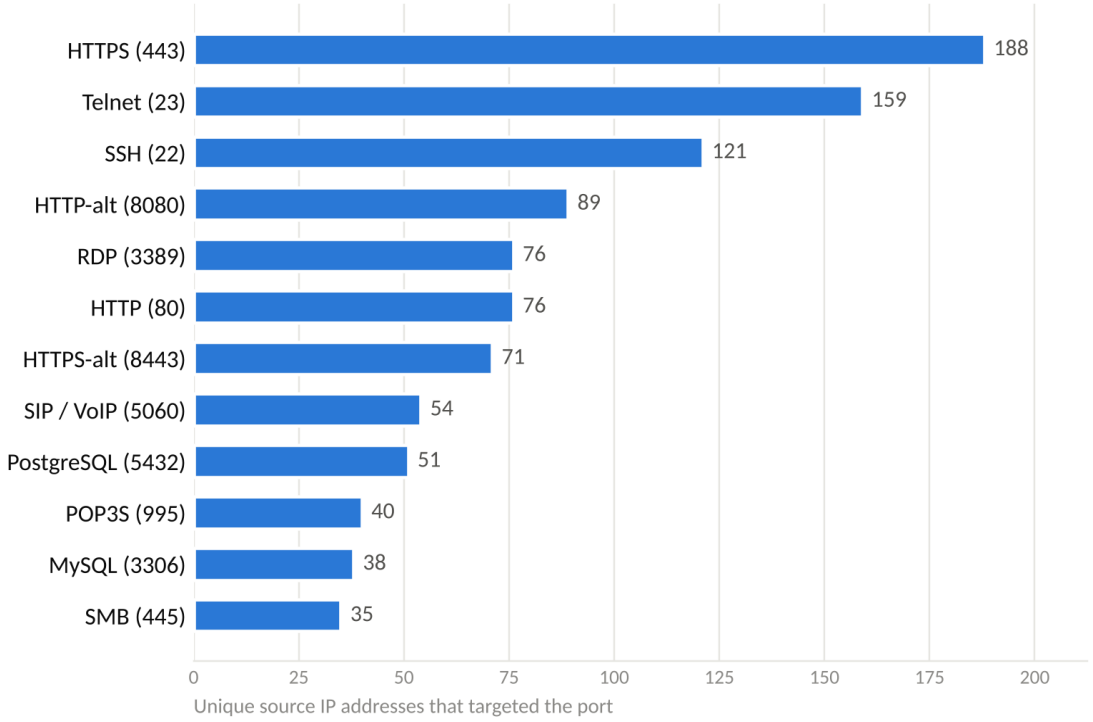


Figure 2. Ports ranked by the number of distinct source IPs that targeted them.

Breadth is one thing, depth is another. Looking only at the decoy services, two attract almost all of the effort:

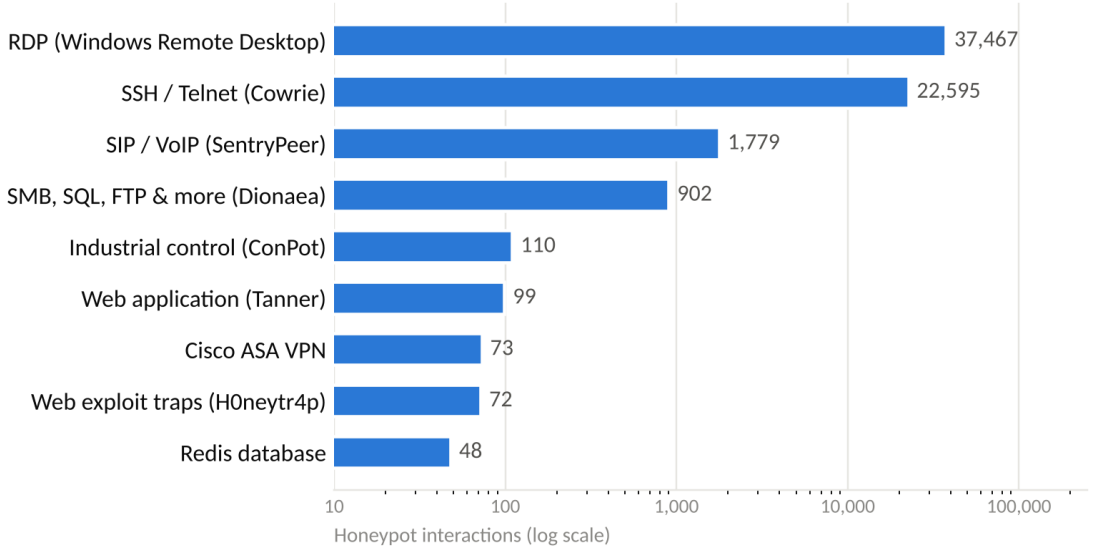


Figure 3. Honeypot interactions by decoy service (log scale: each gridline is 10x the last).

SECTION 05 · BRUTE FORCE

RDP and SSH: the password grind

98.6%
of RDP traffic came from a single host

18,000+
RDP connection attempts by that host

37
addresses tried RDP in total

The RDP decoy was found and then hammered by one rented server: 260,822 events, every one aimed at port 3389. Across all RDP traffic, Suricata raised 37,219 'RDP connection request' alerts and 105 RDP 'SYN then reset' denial-of-service alerts. This is the classic pattern behind ransomware: find exposed RDP, guess passwords until something works, then log in as a human.

SSH and Telnet

4,711
SSH / Telnet sessions from 170 addresses

4,211
login attempts from 46 addresses

98.5%
of SSH clients were automated Go tooling

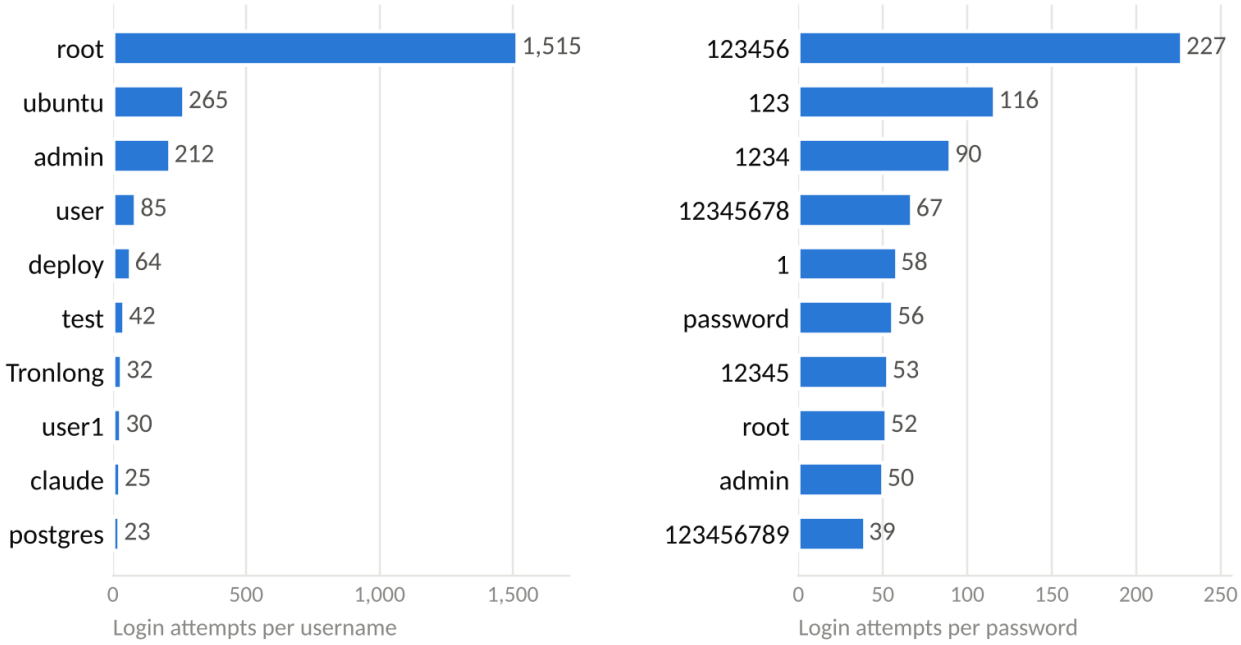


Figure 4. Most-tried usernames (left) and passwords (right) on the SSH and Telnet decoy.

The lists read like a default-settings checklist: `root`, `ubuntu`, `admin`, `postgres`, with passwords like `123456`, `password` and `P@ssw0rd`. The most common pairs were `admin / admin`, `root / 123456` and `ubuntu / ubuntu`. Product-specific names show up too: `Tronlong` (an embedded-board vendor), `lighthouse` (a cloud server image), `minecraft` and `claude`. That last one suggests machines set up for AI coding agents are now on attackers' wordlists.

One hosting network stood out: four of its addresses alone generated 46,019 events, aimed almost entirely at SSH.

SECTION 06 · AFTER THE LOGIN

What attackers do once they are 'in'

Cowrie deliberately accepts some logins so it can watch what happens next. 58 logins were let into its fake shell and 31 addresses typed commands, 470 in total. The behaviour falls into a few clear playbooks:

PLAYBOOK	WHAT WAS SEEN	WHY
IoT botnet escalation	`enable` → `system` → `shell` → `sh` → `linuxshell`, each seen 17 times, in the same order	Breaks out of router and camera menus into a Linux shell. The pattern is typical of Mirai-family botnets.
Find a writable folder	`>/var/run/.x && cd /var/run; >/mnt/.x …; >/dev/shm/.x …; >/tmp/.x …`	Tries folder after folder until one accepts a file, so the malware has somewhere to land
System fingerprinting	`uname -s -v -n -r -m`, `uname -a`	Picks the right malware build for the CPU and OS
Honeypot detection	`printf … "$((423*908+75))"` with random marker strings	Checks whether the shell really does arithmetic, because a weak fake shell would fail the test
Drop and run	Upload a file named `.16` by SCP, `chmod +x`, then pipe guessed passwords into `sudo -S`	Installs the payload and tries to gain root with the same weak passwords

Captured malware

Attackers uploaded files 6 times from 5 different IP addresses. Two unique files were captured. They look like one program: a complete copy and an interrupted upload. They were **not** run and were kept off any working system; only their fingerprints are shared here.

SHA-256	SIZE	SEEN	NOTES
`a151d3f4f2422531f30a843ffb35479596c86722bb103bdf8591105687f9b125`	3,373,344 B	5 uploads, 5 IPs	Linux x86-64 executable (ELF, statically linked), dropped as `.16`; already listed as malicious in public threat-intel feeds
`72b4db8a74da275ed7c51ce919e9e8b6d0897c45e50ad8a4bb748a9b681c7ea5`	2,883,584 B	1 upload	Cut-off copy of the same program (its header expects 3.37 MB), most likely an interrupted upload

Uploading source addresses: 80.94.92.55, 80.94.92.179, 2.57.122.150, 195.178.110.217, 195.178.110.232.

The takeaway

None of this needed a clever exploit. A guessable password was the only way in. From there, getting to an installed bot took a handful of scripted commands. Key-only SSH, no root login and no default passwords would have stopped every one of these sessions.

SECTION 07 · BEYOND PASSWORDS

Exploits, phone fraud, databases and industrial systems

Known vulnerabilities seen in traffic

CVE	PRODUCT AND FLAW	SEVERITY	ALERTS
CVE-2025-55182	React Server Components / Next.js: pre-authentication remote code execution ('React2Shell')	CVSS 10.0	16
CVE-1999-0517	SNMP default, null or missing community string	Legacy	14
CVE-2019-11500	Dovecot IMAP: out-of-bounds write, possible remote code execution	CVSS 9.8	8
CVE-2023-20198	Cisco IOS XE web UI: create a privilege-15 admin account (on CISA's Known Exploited list)	CVSS 10.0	2
CVE-2021-36260	Hikvision camera web server: command injection via `/SDK/webLanguage` (on CISA's Known Exploited list)	CVSS 9.8	7 requests

Exploit attempts are sprayed at every address regardless of what is running there. A sensor that runs neither React nor Cisco still received both. The web decoys also saw probes for FreePBX admin pages and for leaked secrets files such as `/.env` and `/config.json`.

VoIP toll fraud

The SIP decoy logged 1,779 events from 39 addresses: **1,413 INVITE** requests trying to place calls and 323 REGISTER attempts guessing extension accounts. Callers posed as `Linksys-SPA942` and FPBX devices or used the SIPVicious `friendly-scanner`. An exposed phone system with a weak extension password can rack up thousands of dollars in international calls overnight.

Databases and file sharing

Dionaea recorded MySQL (331 connections), PPTP VPN (258), SMB (134), MongoDB (74), MQTT (38) and MSSQL (26), with login names `sa`, `root` and `admin` tried over 100 times each. Suricata also flagged inbound scans for PostgreSQL, MySQL and MSSQL. The Redis decoy received `INFO` reconnaissance commands.

Industrial control systems

17 addresses interacted with the industrial decoy: 96 events used **IEC 60870-5-104**, the telecontrol protocol used by electricity grids and utilities. Another 14 were SNMP queries. Most of this is reconnaissance, but it shows that anything industrial that is reachable from the internet will be found and catalogued.

SECTION 08 · FULL PICTURE

Everything the sensor recorded

For completeness, here is every data source on the sensor that saw outside traffic, with what stood out in each (Cowrie's total includes its 4 public-key login records). The decoys and the network sensors together add up to the 359,560 events in this report.

SOURCE	RECORDS	UNIQUE IPS	WHAT STOOD OUT
RDP honeypot	37,467	37	Windows Remote Desktop logins; 98.6% from one host
Cowrie (SSH / Telnet)	22,599	170	4,211 password guesses, 470 commands, 6 malware uploads, 2 public-key logins as `admin`
SentryPeer (SIP)	1,779	39	1,413 call attempts (INVITE), 323 extension guesses (REGISTER)
Dionaea	902	116	MySQL 331, PPTP VPN 258, SMB 134, MongoDB 74, MQTT 38, MSSQL 26, FTP 23, Windows RPC 18
ConPot (industrial)	110	17	IEC 60870-5-104 grid telecontrol 96, SNMP 14
Tanner (web app)	99	28	General crawling plus FreePBX admin-page probes
Cisco ASA decoy	73	21	Router and device probes (ASUS `appGet.cgi`, `login.cgi`, `SETTINGS.CFG`) and AI `/mcp` endpoint probes
H0neytr4p (web exploits)	72	34	Asterisk / FreePBX call-origination API (`/pbxapi/manager/originate`), `/.env` secrets
Redis	48	12	`PING` and `INFO` reconnaissance
Honeytrap	30	17	Oracle DB (1521), Memcached (11211), UPnP (1900)
Mailoney (SMTP)	16	6	`EHLO`, `STARTTLS` and `AUTH NTLM` probing of a mail server
Heralding	15	4	VNC remote desktop 12, PostgreSQL logins as `postgres` 3
Medpot (medical)	2	2	HL7 healthcare protocol connections
Suricata IDS	132,386	1,161	78,100 alerts from 733 addresses; flows, RDP, SSH, SIP and TLS metadata
P0f	120,980	1,073	Passive operating-system fingerprints
Fatt	42,982	212	Client handshake fingerprints: TLS 20,330, RDP 18,608, SSH 3,920

What the network sensors add

Suricata's threat-intelligence rules matched well-known bad actors: 856 'ET SCAN' alerts for scanning activity (such as Nmap SYN scans and database port sweeps), 439 for sources on the CINS poor-reputation list, 182 each for DShield and Spamhaus DROP blocklisted sources, 120 for 'known compromised or hostile' hosts and 105 for RDP denial-of-service patterns. Only 21 were specific web exploit signatures: most activity is opportunistic, high-volume probing.

Reputation of the 1,168 sources

751 addresses (64%) carried at least one label from the sensor's reputation feeds. Some carried more than one.

LABEL	IPS	LABEL	IPS	LABEL	IPS	LABEL	IPS
Bad reputation	311	Service abuse	55	Compromised	4	Bot activity	3
Scan source	250	SSH abuse	26	Mail abuse	4	SIP abuse	2
Mass scanner	87	Attack source	6	Web attacker	2	Web abuse	1

SECTION 09 · SO WHAT

Lessons for anyone running something online

Nearly everything in this report is automated and opportunistic. That is good news: the defences that stop it are basic, cheap and well understood.

1 **Never expose RDP to the internet**
Put Remote Desktop behind a VPN or zero-trust gateway with MFA. It was the single most attacked service.

2 **SSH by key only**
Turn off password logins and root login. Every intrusion seen here started with a guessed password.

3 **Kill default credentials**
admin/admin, root/123456 and vendor defaults are the first things tried, on every device type.

4 **Patch internet-facing software fast**
React/Next.js, Cisco IOS XE, Hikvision and FreePBX flaws were all being tried. Follow CISA's Known Exploited list and ACSC advisories.

5 **Keep databases and management ports private**
MySQL, MSSQL, MongoDB, Redis, PostgreSQL, SNMP and industrial protocols should never be reachable from the internet.

6 **Lock down VoIP**
No open SIP, use strong extension passwords and restrict international calling to limit toll-fraud losses.

7 **Use reputation blocklists, not country blocks**
64% of sources were already on public lists, while the busiest attacker geolocated to Australia.

8 **Watch, don't just block**
An IDS and centralised logs turn background noise into early warning and show when something gets further than it should.

For Australian businesses

These controls line up with the ACSC Essential Eight, especially multi-factor authentication, patching applications and restricting administrative privileges. If a server faces the internet, assume it is being tested right now, because it is.

APPENDIX

Indicators of compromise

The highest-volume source addresses seen by the sensor. They are shared for blocklisting and abuse reporting. Many will be compromised machines or rented servers rather than the attacker's own, so they may be reassigned over time.

SOURCE IP	NETWORK (ASN)	GEOLOCATION	MAIN TARGET	EVENTS
109.123.227.33	AS141995 Contabo Asia	Australia	RDP 3389	260,822
77.239.124.158	AS198364 Banatsync	United States	SSH 22	16,218
109.160.32.178	AS198364 Banatsync	Bulgaria	SSH 22	16,112
77.239.124.67	AS198364 Banatsync	United States	SSH 22	6,883
77.239.124.39	AS198364 Banatsync	United States	SSH 22	6,806
172.110.223.49	AS47154	Philippines	SIP 5060	2,030
77.90.185.30	AS213790 Limited Network	Germany	MySQL 3306	2,002
27.102.116.43	AS45996 DAOU Technology	South Korea	SSH 22	1,864
154.18.197.29	AS142271 EWS DS Networks	Philippines	SSH 22	1,797
202.169.44.105	AS17451 Biznet Networks	Indonesia	Telnet 23	1,539
93.123.109.6	AS48090 Techoff Srv	Bulgaria	PPTP 1723	1,434

Malware uploaders (SSH / SCP)

80.94.92.55 · 80.94.92.179 · 2.57.122.150 · 195.178.110.217 · 195.178.110.232

Malware SHA-256

a151d3f4f2422531f30a843ffb35479596c86722bb103bdf8591105687f9b125
72b4db8a74da275ed7c51ce919e9e8b6d0897c45e50ad8a4bb748a9b681c7ea5

Notes and sources

- Data: a multi-honeypot sensor with Cowrie, Dionaea, SentryPeer, ConPot, RDP and web honeypots; Suricata IDS with Emerging Threats rules; IP geolocation and ASN from the sensor's built-in GeoIP enrichment; reputation from bundled IP reputation feeds.
- CVE details: NVD (nvd.nist.gov) for CVE-2019-11500, CVE-2021-36260 and CVE-2023-20198; OSV (osv.dev) for CVE-2025-55182; CISA Known Exploited Vulnerabilities catalogue.
- Counts exclude the operator's own management and test traffic, the sensor's own traffic and private address ranges.
- Captured malware was never executed and is not distributed. Hashes are provided so defenders can check their own systems.